

Siber Güvenlik Kanunu

Kurumsal Uyum Checklist'i

7545 sayılı Kanun kapsamında şirketinizin nerede durduğunu on beş maddede gösteren, sorumluluk dağılımlı kontrol listesi.

KANUN NO	7545
YÜRÜRLÜK	19 Mart 2025
İKİNCİL MEVZUAT HEDEFİ	19 Mart 2026
HAZIRLAYAN	Ecem Aksut

Bu doküman genel bilgilendirme amaçlıdır, hukuki görüş niteliği taşımaz. Şirketinizin kapsamı ve yükümlülükleri için kanun metni ve yetkili hukuk danışmanlığı esastır.

Kanun yürürlükte. Belirsizlik bir mazeret değil.

7545 sayılı Siber Güvenlik Kanunu 19 Mart 2025'te Resmî Gazete'de yayımlanarak yürürlüğe girdi. Kanun yalnızca kritik altyapıları değil; bilgi sistemleri üzerinden hizmet sunan, hassas veri işleyen orta ve büyük ölçekli tüm şirketleri ilgilendiren yükümlülükler ve cezai yaptırımlar getiriyor.

İkincil mevzuatın bir yıl içinde, yani 19 Mart 2026'ya kadar tamamlanması öngörüldü. Bu takvim büyük ölçüde kaydı. Sonuç: yükümlülük yürürlükte, ancak uygulama detayları henüz net değil. Birçok şirket bu boşluğu uyumu erteleme gerekçesi olarak kullanıyor.

Sorun şu: denetim ve bilgi-belge talep etme yetkisi netlik beklemiyor. Aşağıdaki on beş madde, şirketinizin bu boşlukta nerede durduğunu görmenizi sağlar. Her maddenin yanında birincil sorumluluğun kimde olduğunu işaretledik: yönetim kurulu, hukuk veya bilgi teknolojileri.

CEZA TABLOSU · ÖZET

İHLAL	YAPTIRIM
Bilgi / belge vermeme	1-3 yıl hapis + adli para cezası
Denetime engel olma	100.000 - 1.000.000 TL (brüt hasılatın %5'ine kadar)
Güvenlik tedbirlerine uymama	1.000.000 - 10.000.000 TL idari para cezası
Olay bildirimini yapmama	1.000.000 - 10.000.000 TL idari para cezası
İzinsiz faaliyet	2-4 yıl hapis + 1.000-2.000 gün adli para cezası
Veri sızıntısı / izinsiz paylaşım	3-5 yıl hapis cezası

Yaptırımlar kanun metni ve kamuya açık hukuk değerlendirmelerine dayanır; alt düzenlemelerle somutlaşacaktır.

Şirketiniz kapsamda mı, hazır mı?

Her maddeyi işaretleyin. İşaretlenmeyen her kutu, kapatılması gereken bir açıktır. Köşeli parantez içindeki etiket birincil sorumluyu gösterir.

- ☐ **1. Kapsam tespiti yapıldı**
Şirketin kanun kapsamında olup olmadığı yazılı olarak değerlendirildi; karar varsayıma değil kanun metnine dayandırıldı. [YÖNETİM KURULU + HUKUK]
- ☐ **2. Bilgi varlık envanteri çıkarıldı**
Kritik sistemler, yazılımlar, veri tabanları ve ağ topolojisi haritalandı; hangi varlığın kanun kapsamına girdiği belirlendi. [BİLGİ TEKNOLOJİLERİ]
- ☐ **3. Siber risk analizi tamamlandı**
Teknik ve operasyonel boyutta risk analizi yapıldı; en yüksek riskli varlıklar önceliklendirildi. [BİLGİ TEKNOLOJİLERİ + RİSK]
- ☐ **4. Sorumluluk dağılımı yazılı tanımlandı**
Her yükümlülüğün sahibi (kurul, hukuk, IT) yazılı bir matriste belirlendi; 'herhalde IT'dedir' belirsizliği ortadan kaldırıldı. [YÖNETİM KURULU]
- ☐ **5. Olay müdahale ve raporlama süreci kuruldu**
Siber olay tespit, müdahale ve Başkanlığa bildirim akışı yazıya döküldü; sorumlu kişiler atandı. [BİLGİ TEKNOLOJİLERİ + HUKUK]
- ☐ **6. Olay bildirim takvimi netleştirildi**
Bir olay gerçekleştiğinde kime, ne zaman, hangi formatta bildirim yapılacağı tanımlandı. Bildirim yapmama 10 milyon TL'ye kadar cezalıdır. [HUKUK + IT]
- ☐ **7. Bilgi-belge sunma hazırlığı yapıldı**
Denetim görevlisi bilgi, belge, yazılım, veri veya donanım talep ettiğinde tam ve zamanında sunulabilmesi için süreç hazır. [HUKUK + IT]
- ☐ **8. Tedarikçi ve ürün uyumu gözden geçirildi**
Kullanılan siber güvenlik ürün ve hizmetlerinin sertifikasyon / yetkilendirme durumu kontrol edildi; yerli-milli öncelik politikası değerlendirildi. [SATIN ALMA + IT]
- ☐ **9. İç denetim ve test programı oluşturuldu**
Düzenli iç denetim, sızma testi ve risk analizi takvimi belirlendi; bağımsız denetime hazırlık yapıldı. [İÇ DENETİM]
- ☐ **10. Yönetim kurulu bilgilendirildi**
Kanunun yarattığı yükümlülük, ceza riski ve bütçe ihtiyacı üst yönetime raporlandı; bu bir IT konusu olarak değil yönetim konusu olarak ele alındı. [YÖNETİM KURULU]
- ☐ **11. Bütçe ve insan kaynağı planlandı**
Uyum için gereken yatırım, personel ve dış danışmanlık ihtiyacı planlandı ve onaylandı. [YÖNETİM KURULU + İK]
- ☐ **12. Sır saklama ve gizlilik yükümlülükleri kuruldu**
Kanun kapsamında elde edilen bilgilerin gizliliğine dair iç politikalar ve sözleşme hükümleri güncellendi. [HUKUK]

- ☐ **13. KVKK ve diğer mevzuatla uyum sağlandı**
Siber güvenlik uyumu KVKK, ISO 27001 ve sektörel düzenlemelerle çelişmeyecek şekilde entegre edildi. [HUKUK + IT]
- ☐ **14. Birleşme / devir / pay işlemleri kontrol edildi**
Şirket siber güvenlik alanında faaliyet gösteriyorsa, birleşme, bölünme, pay devri ve satış işlemlerinin Başkanlık onayına tabi olduğu süreçlere işlendi. [HUKUK]
- ☐ **15. Uyum yol haritası tarihlendirildi**
Eksik maddeler için sorumlusu ve bitiş tarihi belirlenmiş bir yol haritası oluşturuldu. 'Süreç devam ediyor' yerine somut tarih konuldu. [YÖNETİM KURULU]

DEĞERLENDİRME

Kaç kutu işaretlediniz?

12 - 15 Olgun.

Uyum yönetim seviyesinde ele alınmış. Denetime hazırsınız; sürekliliği koruyun.

7 - 11 Geçiş halinde.

Temel atılmış ama kritik açıklar var. İşaretlenmeyen maddelere tarih ve sorumlu atayın.

0 - 6 Riskli.

Yükümlülük yürürlükte, hazırlık değil. Önce kapsam tespiti ve sorumluluk dağılımıyla başlayın.

Bu checklist The Governance'tan.

Türkiye'nin bağımsız GRC yayını. Risk, uyum, iç denetim ve yönetim üzerine her hafta tek bir keskin analiz: doğrudan e-postanıza.

thegovernance.beehiiv.com